CHARTERED ACCOUNTANTS ACADEMY

AUDITING DEPARTMENT

CERTIFICATE OF THEORY IN ACCOUNTING

STUDY UNIT 7 – PLANNING THE AUDIT PHASE 2

TABLE OF CONTENTS **PAGE**

Contents

1. Introduction 211
2. Objectives of understanding of the entity and its environment 211
3. Scope 211
4. Study material 212
5. Competence Framework expectation 212
6. Examination possibilities 212
7. Assumed Knowledge 212
8. Integration 213
9. Course notes 214
9.1. Obtain an understanding of the client's systems and control environment. 214
9.2. Business Cycles: 214
9.3. Why do we need controls? 214
9.4. The internal control objectives 214
9.5. Limitations of Internal Control 214
9.6. Internal Control Components – ISA 315 par A58 215
9.7. Control Environment 216
9.8. The entity's risk assessment process 216
9.9. Information systems and related business processes relevant to financial reporting 216
9.10. Control Activities 217
9.11. Monitoring of Controls 217
9.12. Designing a system of controls 218
9.13. Assessing control risk 220
9.14. General Controls vs. application controls 221
9.15. IT General Controls (ITGC) 222
10. ISA 265: COMMUNICATING DEFICIENCIES IN INTERNAL CONTROL TO THOSE CHARGED WITH GOVERNANCE AND MANAGEMENT 228
10.1. Introduction 228
Communication requirements 229
IT Governance 229
Question on planning – understanding and evaluating the control environment 231

1. Introduction

Obtaining an understanding of the entity and its environment, including its internal control forms part of the planning phase of the audit process. For ease of discussion, the basic concepts that will be addressed are as follows:

1. Internal control and business cycles.

2. General and application controls.

3. Advanced CIS environment.

4. IT Governance.

2. Objectives of understanding of the entity and its environment

After the completion of this study unit, you should be able to:

- apply your knowledge of the various business cycles;
- apply your knowledge of internal control and its components;
- design systems of internal control;
- describe why it is necessary to obtain an understanding of the accounting and internal control systems during the planning phase of the audit;
- evaluate the effectiveness of an internal control system, identify weaknesses and/or consequences and advise on possible improvements to the system;
- evaluate findings and report weaknesses;
- describe the impact of controls on the audit approach;
- discuss the various methods of information processing and be able to
- differentiate between the different computerised systems environments;
- evaluate the general control environment as well as a specific computer system's application controls;
- apply your knowledge of advanced computer technology as well as how it affects transaction processing and the system of internal controls in a computerised information system (CIS) environment;

3. Scope

- ISA 265: Communicating deficiencies in internal control to those charged with governance and management.
- ISA 300: Planning an audit of financial statements.
- ISA 315: Identifying and assessing the risks of material misstatement through understanding the entity and its environment.
- ISA 330: The auditor's responses to assessed risks.
- ISA 402: Audit considerations relating to an entity using a service organisation.

4. Study material

- CAA Applied Auditing and Governance Module 1 (AUD 402) – Study unit G
- Auditing Notes
- International Standards on Auditing

5. Competence Framework expectation

- Undertake risk assessment procedures to obtain / update an understanding of the entity and its environment, including its internal controls
- Based on the understanding, identify the specific risks that could result in material misstatement of the subject matter, including fraud risk factors
- Assess the risk of material misstatement in the subject matter at the overall and assertion levels

6. Examination possibilities

- Description of controls you would expect to be in place over a business cycle e.g. sales cycle. Be open to applying knowledge over a computerised business cycle given the vast technological advancements in today's world.
- Describing the general IT controls that should be in place over a computerised system
- Describe the application controls that should be in place
- State the internal control objectives for a given system or function/stage within such a system
- Identify weaknesses in a system and make recommendations for improvement;
- Criticise an existing system of control;
- Assess the control risk for a given transaction;

7. Assumed Knowledge

- It is very important that you meticulously work through the theory in Auditing Notes regarding the business cycles. This will build the foundation that you will need to answer questions relating to risks in a manual and CIS environment.
- It is not sufficient to only work through this tutorial pack. The information contained in the relevant chapters in Auditing Notes is not duplicated in the tutorial pack and should be studied from Auditing Notes. You will miss crucial information if you do not study the relevant chapters from Auditing Notes.
- You need to be comfortable with the basic knowledge (from undergraduate studies and prescribed study material) before attempting any questions. We as lecturers can clearly see in a test/examination which students have a lack of basic knowledge, specifically relating to computer auditing. It is highly unlikely that you will ever audit in a fully manual environment. You must, however, be able to apply the basic principles of auditing in a manual environment, to an audit in a computerised environment.

- You have to be comfortable with these basic principles in a manual system before moving on to the more complex principles of auditing in a computerised information system (CIS) environment.
- Due to its integrated nature, computer auditing should not be seen in isolation. It can be combined and integrated into almost all the other auditing topics and tutorial letters. You can therefore expect integrated computer auditing questions in almost every test during the year, the final examination and on board level.
- We as lecturers do not expect you to be Information Technology (IT) experts. The basic concepts covered in this tutorial letter and in the relevant chapters of Auditing Notes should be sufficient for you to answer computer related questions.

8. Integration

This topic can be integrated with any financial accounting standard, management accounting and finance and taxation topics. Its highly examinable.

9. Course notes

9.1. Obtain an understanding of the client's systems and control environment.

Setting the scene:
During the planning stage the auditor is required to assess control risk and to determine whether or not to place reliance over a client's system of internal control (part of the audit approach). In order to do this the auditor must have a thorough understanding of **the internal control objectives** and the types of controls that should be in place at the client to achieve these objectives.

If there are **control weaknesses** in the client's systems this will result in a higher control risk and is likely to result in the auditor taking a fully substantive audit approach.

9.2. Business Cycles:

Student should revise their **auditing notes** on business cycles in order to have an appreciation of how transactions are processed. Examples of business cycles include:

- Revenue cycle
- Purchases cycle
- Payroll cycle

9.3. Why do we need controls?

Therefore, from the above it is clear that the need for controls is driven by the presence of risks or what can go wrongs in the achievement of an entities objective.

9.4. The internal control objectives

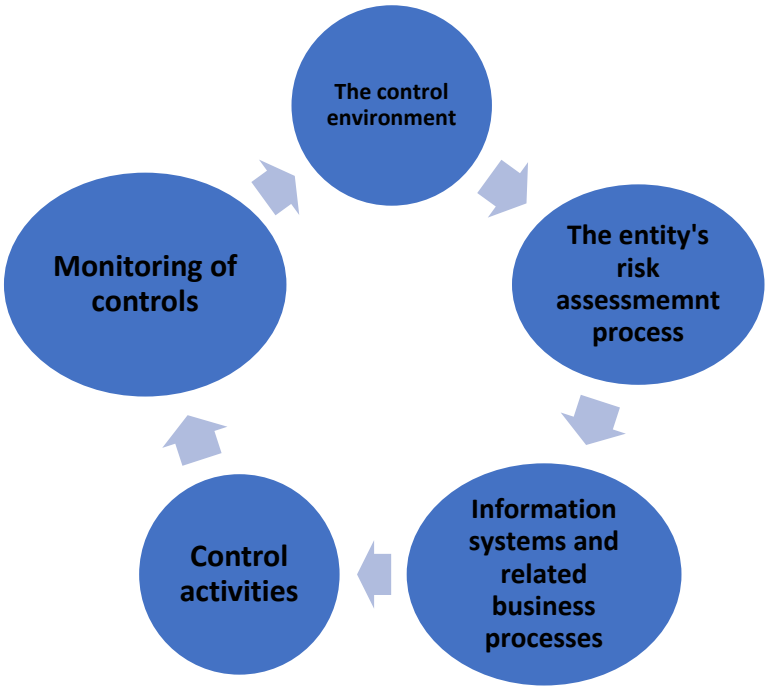
Management has certain objectives when running their business. Broadly put internal controls are designed, implemented and maintained to address identified business risks that threaten the achievement of any of the entity's objectives that concern:

- The reliability of the entity's financial reporting;
- The effectiveness and efficiency of its operations; and
- Its compliance with applicable laws and regulations.

9.5. Limitations of Internal Control

Internal control, no matter how effective, can provide an entity with only reasonable assurance about achieving the entity's financial reporting objectives. The likelihood of their achievement is affected by the inherent limitations of internal control. These include the realities that human judgment in decision-making can be faulty and that breakdowns in internal control can occur because of human error.

9.6. Internal Control Components – ISA 315R



9.7. Control Environment

The control environment includes the governance and management functions and the attitudes, awareness, and actions of those charged with governance and management concerning the entity's internal control and its importance in the entity. The control environment sets the tone of an organization, influencing the control consciousness of its people. Elements of a control environment include the following:

a) Communication and enforcement of integrity and ethical values;
b) Commitment to competence;
c) Participation by those charged with governance;
d) Management's philosophy and operating style;
e) Organisational structure;
f) Assignment of authority and responsibility;
g) Human resources policies and practices – for example, polices on recruitment, training and promotion.

9.8. The entity's risk assessment process

The entity's risk assessment process forms the basis for how management determines the risks to be managed. If that process is appropriate to the circumstances, including the nature, size and complexity of the entity, it assists the auditor in identifying risks of material misstatement.

9.9. Information systems and related business processes relevant to financial reporting

The information system relevant to financial reporting objectives, which includes the accounting system, consists of the procedures and records designed and established to:

- Initiate, record, process, and report entity transactions (as well as events and conditions) and to maintain accountability for the related assets, liabilities, and equity;
- Resolve incorrect processing of transactions, for example, automated suspense files and procedures followed to clear suspense items out on a timely basis;
- Transfer information from transaction processing systems to the general ledger;
- Capture information relevant to financial reporting for events and conditions other than transactions, such as the depreciation and amortization of assets and changes in the recoverability of accounts receivables; and
- Ensure information required to be disclosed by the applicable financial reporting framework is accumulated, recorded, processed, summarized and appropriately reported in the financial statements.

Related Business processes:

An entity's business processes are the activities designed to:

- Develop, purchase, produce, sell and distribute an entity's products and services;
- Ensure compliance with laws and regulations; and
- Record information, including accounting and financial reporting information.

Examples of business processes may include, payroll cycle, procurement cycle and payments cycle.

9.10. Control Activities

Control activities are the policies and procedures **that help ensure** that management directives are carried out. Control activities, whether within IT or manual systems, have various objectives and are applied at various organizational and functional levels. Examples of specific control activities include those relating to the following:

- Authorization.
- Performance reviews.
- Information processing.
- Physical controls.
- Segregation of duties.

9.11. Monitoring of Controls

Monitoring of controls is a process to assess the effectiveness of internal control performance over time. It involves assessing the effectiveness of controls on a timely basis and taking necessary remedial actions. Management accomplishes monitoring of controls through ongoing activities, separate evaluations, or a combination of the two. Ongoing monitoring activities are often built into the normal recurring activities of an entity and include regular management and supervisory activities. An entity's internal audit function can play a role in the monitoring of an entity's internal controls over financial reporting.

The auditor is concerned only with controls that achieve the integrity objectives. These objectives correspond to the auditing assertions for transactions as follows:

Internal control objective	Related transactional assertion(s)	Difference
Validity: ▪ Transactions are genuine ▪ Transactions are in terms of management policy	Occurrence: ▪ Transactions are genuine and meet the IFRS recognition criteria	Occurrence does not take into Account management policy. A transaction can be Outside management policy (i.e. not valid) but still have occurred.
Accuracy: ▪ Transactions are recorded at the correct amount ▪ Transactions are recorded in the correct account	Accuracy & classification ▪ Transactions are recorded at the correct amount ▪ Transactions are recorded in the correct account and correctly classified	None
Completeness: ▪ All valid transactions are recorded ▪ Transactions are recorded in the correct accounting period	Completeness & Cut off ▪ All transactions that meet the IFRS recognition criteria are recorded ▪ Transactions are recorded in the correct accounting period	None

In order to achieve their internal control objectives management must first identify any threats to these objectives (i.e. risks). They must then design controls to mitigate the risks identified. Any risk that is not mitigated by controls is called a weakness.

9.12. Designing a system of controls

In order to design a system of controls, students should do the following:

1. Identify the functions/stages of the cycle for which are required to design controls, and the person responsible for each function.
    - In a purchasing system for example the functions might be ordering, receipt, recording the invoices, and accounting.
    - In a hairdressing salon however they might be booking, styling (a.k.a. performing the service), cash payment, and accounting.

2. Identify the documents used in each function/stage of the cycle.

- In a purchasing system for example the documents would be an order form; goods received note, a supplier invoice and the purchases journal.
- These documents could be either manual (hard-copy) or computerised.

3. Identify the type of information that would be recorded on each document. These would usually fall into the following categories:
    - Person. The person with whom the business has transacted.
    - Price. The price per unit of goods or services in the transaction.
    - Quantity. The quantity of goods, services, or hours in the transaction.
    - Description. Description of the goods or services to which the transaction relates.
    - Date. The timing of the transaction.
    - Total value. Quantity X Price.
4. Based on your understanding of the above **identify the risks or what can go wrong** in processing the transaction based on the entities objectives. Examples would include:
    - The incorrect price may be used in processing the transactions
    - An individual without the proper authority may process a transaction
    - Not all transactions are recorded
    - Fictitious sale may be recorded
    - Unauthorised access to the system

5. After the identification of the above risks you should then come up with controls to mitigate the risks. Refer to the table below for an example:

Risk/ What can go wrong	**Control procedure**
A till operator may use the incorrect price when processing a sale	▪ Use of bar codes to reduce input errors.
An individual without the proper authority may process payments	▪ All payments are reviewed and authorized before they are authorised
Goods received are not recorded	▪ Good receiving vouchers are sequentially numbered and system performs a sequence check.
Unauthorised access to the system.	▪ Restrict access through the use of unique usernames and password.
Unauthorised changes may be made to the system	▪ Limit access rights to the system by giving read only access to users are not supposed to be making any changes to the system.

a. Students should read the required carefully to determine which functions/stages are within the scope of the question. For example, if students are asked to design controls over the ordering of goods then there would be no marks awarded for listing control relating to payment for goods etc.

b. Students should also read the required to determine whether they are required to design controls over all objectives or whether they are only required to design controls over a specific objective.

Before coming up with the control or identifying control weaknesses the students should first identify the potential risk that should be mitigated.

Exam tip!!!

Students should never explain a control weakness by stating that certain controls are missing. Instead, students should state what could go wrong as a result of "missing" controls. If, for example, purchase orders are not authorised, the weakness would be that orders may not be in terms of management policy. The lack of authorisation is not a weakness in itself! Students may find it helpful to write all weaknesses as follows: "the risk is that…"

Identifying internal control weakness and making recommendations

When asked to identify control weaknesses students should:

i. Identify risks to the internal control objectives for the given system.
ii. Check to see if there are any controls in place to mitigate these risks.
iii. If there is no control to mitigate a specific risk then the risk is a weakness.

When asked to make recommendations students should list controls that would achieve the internal control objective to which the weakness relates. For example if the weakness related to fictitious transactions being processed, a student would be expected to recommend controls over validity.

Exam tip!!!!!

9.13. Assessing control risk

Control risk is the risk that the client's controls will not mitigate their inherent risks. Control risk is decreased by having strong controls in place. It is increased by having obvious control weaknesses.

When assessing control risk for a specific balance or transaction, students should use the following approach:

- Identify controls that are already in place over the balance or transaction and state that these controls reduce the control risk.
- Identify the control weaknesses in the system and state that these increase the control risk.

9.14. General Controls vs. application controls

General controls	▪ Umbrella controls under which each application will operate ▪ To provide assurance that overall objectives of internal control are achieved ▪ To ensure that the computer system is properly developed, implemented and maintained Examples: ▪ Appointment of an audit committee ▪ Staff training ▪ Recruitment policies ▪ Testing of a new system
Application controls	▪ Controls over input, processing & output of **information/transactions** to ensure it is valid, accurate & complete. ▪ Consists of user & programmed controls ▪ Specific controls in each application/business process to prevent detect and correct user errors as transaction flow through system. ▪ Although application differs, the control principle for all applications is the same. Examples: ▪ Use of drop down menus ▪ Use of a password to access an application ▪ Review of a purchase order by the senior buyer. ▪ Counting of goods received and matching them to delivery note

Exam tip

Application controls can both be programmed controls and manual controls!!!!

9.15. IT General Controls (ITGC)

General IT controls are those in place over the entire computerised environment. These controls are essential and if they are not implemented then the integrity of all computerised information will be compromised. Thus the operational effectiveness of computerised application controls is completely dependent on the functioning of the general IT controls.

The following general IT controls should be in place over all computerised systems:

1. Control environment and security
    - Management should lead by example and behave in an ethical manner.
    - Management should be fully committed to risk management.
    - Management should communicate and enforce the importance of good controls to all IT staff.
    - Management should implement a clear security policy over hardware and software based on the least privilege principle.

2. Organisational structure and personnel practices
    - There should be clear reporting lines and levels of authority established by management.
    - There should be segregation of duties:
        - Between the IT department and user departments; and
        - Within the IT department between the duties of database administration, systems design, programming and processing.
    - Strict recruitment and training policies and procedures should be implemented by management.
    - Staff should be forced to take compulsory leave on a regular basis (providing an opportunity for fraud to be uncovered).
    - Personnel practices should be documented in writing.

3. Standardised operating procedures
    - Standard operating procedures should be in place over:
        - Scheduling of jobs;
        - Maintenance of hardware and software; and
        - Machine servicing.

4. System development and change controls
    - Any development of new systems or change of existing systems should be:
        - Authorised in writing by the IT manager if related to the operating system as a whole;
        - Authorised in writing by the IT manager and the user manager if related to an individual module within the system (e.g. the sales module);
        - Documented on pre-numbered, pre-printed installation or change forms;

        - Implemented using standardised procedures and techniques;
        - Planned by systems analysts;
        - Implemented by experienced programmers; and
        - Tested extensively prior to finalisation.
    - Changes should be made only to test versions of programmes and not the live versions.
    - All changes to the system should be automatically logged, and the IT manager should regularly review this log for unauthorised changes.
    - Data should be backed up prior to installation or change.
    - Any conversion of data should be carefully planned.
    - Access controls should be used to prevent unauthorised changes being made to the system. These would be similar to the application access controls.
    - Staff should be trained on the new system.
    - Post-implementation reviews should be carried out by management.
5. Continuity of operations
    - Adequate backup procedures should be introduced for programmes and data.
    - A disaster recovery plan should be introduced and the plan should be updated regularly.
    - There should be alternative processing facilities in the event of an emergency.
    - Adequate insurance should be taken out to cover losses in case of an emergency.
    - The system should be protected against fire, water damage etc. through the use of fire alarms, fire extinguishers, and the use of air-conditioning.

6. Access controls
    - The following physical access controls should be implemented over the premises in which computer facilities are housed:
        - Security checks should be performed on all visitors before they are allowed to enter;
        - All visitors are logged and given an identification tag;
        - All doors to buildings and rooms should be locked, with only authorised personnel having keys; and
        - CCTV should monitor all activity.
    - All systems should be protected the following logical access controls:
        - Users are required to enter user ID and password before being granted access; and
        - All sensitive data is encrypted.

Exam tip!!!!

1. The general IT controls listed above should be in place over all computerised system;

2. The ITC has regularly required students to describe the controls that should be in place over the transfer of data from one system to another or the installation of a new system. This is essentially a systems change and the controls in point 4 above would therefore apply; and

3. Students should read the required carefully to determine whether they are being asked to describe general IT controls or application controls. If they address the wrong type of controls they will not get marks.

Overall SCRUM general controls

Apply SCRUM as far as possible for easy marks when the required asks you to provide appropriate controls – Segregation of duties; Custody of assets; Reconciliations; Control over Unused stationery; Management supervision.

Control	**Control Objective**
Segregation of duties: The same person should not be responsible for multiple functions within a function. (Students must state exactly who should perform each function in order to achieve this).	Validity
Custody of assets ▪ Assets should be kept behind locked doors. Only authorised personnel should be given keys. ▪ Security guards should monitor access to the premises. ▪ Visitors should be required to show identification before entering the premises and visitors should sign a log book to document their visit. ▪ CCTV cameras should be in place to monitor assets (Students should state which assets the above controls should be over – inventory, cash, etc.).	Validity
Reconciliations ▪ Subsidiary ledgers to be reconciled to control accounts (e.g. debtors' ledger to accounts receivable control account). ▪ Between documents from subsequent stages (e.g. reconcile amounts on invoices to amounts on delivery notes and orders).	Validity/accuracy/completeness
Controls over unused documents: Unused documents should be: ▪ Difficult to copy; ▪ Crossed when no longer in use; and ▪ Kept in a safe with only management having keys. Documents should be issued to staff only when	Validity

necessary and: ▪ This should be logged; and ▪ Both the staff member and management to sign as evidence of issuance.	
Management controls: Management should set policies and communicate these with staff. Policies might include those over: ▪ Limits (overtime hours, credit limits, wage rates etc.); ▪ Authorised suppliers; and ▪ Hiring and firing of staff. Management should give specific authorisation for any override of policy (evidence by signature). Management should review the following: ▪ Logs of documents issued; ▪ Reconciliations carried out by employees; and ▪ Customer/employee complaints. Management should train staff on the operation of controls. Management should monitor the operation of controls by performing spot checks.	Validity Validity Validity/accuracy/completeness Validity/accuracy/completeness Validity/accuracy/completeness

Computer application controls

Control	Related control objective
Access controls Physical access controls: ▪ Terminals should be kept in a secure office to which only authorised person have keys and door should be kept locked when not in room. Logical access controls: ▪ Access to be restricted in terms of access tables at both system and application level based on least privileged basis. ▪ All terminals and sensitive applications to require ID and passwords to be entered: o Passwords must be unique; o Passwords to consist of mixture of numbers and letters; o Password files to be encrypted; o Password required to be changed every 90 days; and o Password should never be shown on screen. ▪ Application or interface should automatically log out if left idle for longer than 10 minutes. ▪ Terminal should be automatically blocked if the incorrect password is entered more than three times. Access violations to be logged automatically. ▪ Firewalls should be in place to prevent unauthorised access through internet. ▪ All sensitive data should be encrypted. ▪ Anti-virus software to be installed on all terminals. ▪ Assurance logos to be shown on websites.	Validity
Minimising human input Human input should be minimised using the following: ▪ Scanners ▪ Drop down menus ▪ Touch screens ▪ Pre-populated fields	Accuracy
Edit-validation checks The following could be programmed into the system: ▪ Missing sequence number checks (completeness); ▪ Limit and range checks (accuracy); ▪ Alpha-numeric checks (accuracy); ▪ Duplicate checks (validity); ▪ Sequence checks (completeness); and ▪ Verification checks against master file data (Students must state exactly what data the above checks would be applied to)	Validity/accuracy/completeness

Management computer controls ▪ Management to set policies over password confidentiality. Management to grant access to modules/functions on least privileged basis. ▪ Management to review the following and follow up on any unusual items: Audit trails: ▪ Exception reports (see below); ▪ Activity reports (all objectives); and ▪ Access violation reports. Exception reports may include reports of: ▪ Duplicate entries ▪ Negative amounts ▪ Zero amounts ▪ Missing sequence numbers ▪ Access outside normal hours ▪ Transactions outside established ranges o Minimum<rates>maximum o Minimum<quantity>maximum Management to train all staff on the use of computers Management to provide staff with help manuals	Validity, accuracy/completeness
Master file update controls ▪ Management should authorise all amendments prior to implementation. All amendments should be automatically logged: ▪ Management to review log on regular basis and follow up on unauthorised changes. ▪ Logical access controls should be in place to ensure that only authorised persons can amend the master file (see detail under "access controls") Edit-validation checks should be programmed into the master file to prevent errors (see detail under "edit validation")	Validity/accuracy/completeness

10. ISA 265: COMMUNICATING DEFICIENCIES IN INTERNAL CONTROL TO THOSE CHARGED WITH GOVERNANCE AND MANAGEMENT

10.1. Introduction

The auditor is required to obtain an understanding of internal control relevant to the audit when identifying and assessing the risks of material misstatement. In making those risk assessments, the auditor considers internal control in order to design audit procedures that are appropriate in the circumstances, but not for the purpose of expressing an opinion on the effectiveness of internal control.

The auditor may identify deficiencies in internal control not only during this risk assessment process but also at any other stage of the audit. This ISA specifies which identified deficiencies the auditor is required to communicate to those charged with governance and management.

Definitions

Deficiency in internal control	This exists when: (i) A control is designed, implemented or operated in such a way that it is unable to prevent, or detect and correct, misstatements in the financial statements on a timely basis; or (ii) A control necessary to prevent, or detect and correct, misstatements in the financial statements on a timely basis is missing.
Significant deficiency in internal control	A deficiency or combination of deficiencies in internal control that, in the auditor's **professional judgment**, is of sufficient importance to merit the attention of those charged with governance. The significance of a deficiency or a combination of deficiencies in internal control depends not only on whether a misstatement has actually occurred, but also on the likelihood that a misstatement could occur and the potential magnitude of the misstatement.

Communication requirements

1. The auditor shall communicate in writing significant deficiencies in internal control identified during the audit to those charged with governance on a timely basis.
2. The auditor shall also communicate to management at an appropriate level of responsibility on a timely basis:
   a) In writing, significant deficiencies in internal control that the auditor has communicated or intends to communicate to those charged with governance, unless it would be inappropriate to communicate directly to management in the circumstances; and
   b) Other deficiencies in internal control identified during the audit that have not been communicated to management by other parties and that, in the auditor's professional judgment, are of sufficient importance to merit management's attention.

IT Governance

Information technology is becoming more important for every aspect of business.
As per the 2009 King III Code of governance:
"Information systems were used as enablers to business, but have now become pervasive in the sense that they are built into the strategy of the business. The pervasiveness of IT in business today mandates the governance of IT as a corporate imperative.

In most companies, IT has become an integral part of the business and is fundamental to support, sustain and grow the business. Not only is IT an operational enabler for a company, it is an important strategic asset to create opportunities and to gain competitive advantage. Companies have made, and continue to make a significant investment in IT. Virtually all components, aspects and processes of a company include some form of automation. This has resulted in companies relying enormously on IT systems. Further, the emergence and evolution of the internet, ecommerce, on-line trading and electronic communication have also enabled companies to conduct business electronically and perform transactions instantly. These developments bring about significant risks and should be well governed and controlled.

We, therefore, deal with IT governance in detail in King III for the first time. The IT governance chapter (Chapter 5) is focused on providing the most salient aspects of IT governance for directors. Due to the broad and ever-evolving nature of the discipline of IT

There is no doubt that the complexity of IT systems does create operational risks and when one outsources IT services, for instance, this has the potential to increase risk because confidential information is outside the company. Consideration has to be given to the integrity and availability of the functioning of the system; possession of the system; authenticity of system information; and assurance that the system is usable and useful. Concerns include unauthorised use, access, disclosure, disruption or change to the information system.

In exercising their duty of care, directors should ensure that prudent and reasonable steps have been taken in regard to IT governance. To address this by legislation alone is not the answer. International guidelines have been developed through organisations such as ITGI and

ISACA (COBIT and Val IT), the ISO authorities (e.g.: ISO 38500) and various other organisations such as OCEG. These may be used as a framework or audit for the adequacy of the company's information governance for instance, but it is not possible to have 'one size fits all'. However, companies should keep abreast of the rapidly expanding regulatory requirements pertaining to information."

Question on planning – understanding and evaluating the control environment

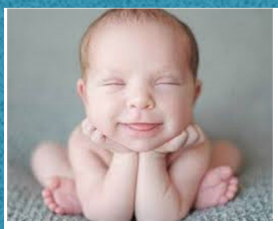
MeBaby

You are the auditor of MeBaby (Pvt) Ltd. ("MeBaby") and currently in the process of planning the audit for the financial year ending 30 September 2014. MeBaby, is an established company in the Zimbabwean retail sector. Its products include various baby essentials as well as luxury items including, amongst others, baby skin care, bath and feeding products, cot linen, baby monitors, nursery decor, baby clothing and toys.

MeBaby is planning on listing on the Zimbabwe Stock Exchange during early 2015, having grown substantially in the past couple of years. The company's exponential growth can be attributed to an extensive product range, including top industry brands such as Dr Browns, Phillips, NUK and Nestle, and goods whose quality and durability meets customers' needs at competitively low prices. MeBaby currently operates 14 large retail outlets throughout Zimbabwe, where products are sold to the general public. The company has one wholly owned subsidiary, Tots 'n Tods (Pvt) Ltd. which specialises in toys and clothing for toddlers. This shareholding was purchased in 2012 as part of MeBaby's expansion plans, in anticipation of its 2015 listing.

At the beginning of the financial year, on 1st October 2013, MeBaby decided to expand their business by establishing and launching "MeBaby.co.zw" - an online baby mega-store. The intention for the website was to assist Zimbabwean parents to source a massive range of top-branded baby products online, thus bringing local and international brands to their doorsteps. In addition to offering the identical extensive range of products offered at their retail outlets, the online store was the first in Zimbabwe to feature innovative and brand new products not yet available at any other Zimbabwean retailers, (including their own retail outlets). In a short space of time, the 'store' has become a trusted and popular site encompassing the MeBaby superior product range together with reliable and effective customer service.

The following has been extracted from the stores website at www.MeBaby.co.zw:



WELCOME. We know that a shopping expedition whilst heavily pregnant or with a newborn baby is not the most pleasant experience! Our online store has thus been designed keeping in mind the hardworking parent with limited time trying to keep it all together. Until now, parents in ZIM have not enjoyed the luxury of being able to easily source novel, innovative and top-quality baby products with online shopping, like mothers in other countries have been able to do for so long. With thousands of products being offered to you, and our websites ease of use, we know that we will meet your needs. Unlike other sites with exorbitant delivery costs, MeBaby delivers all purchases over $100, free of charge anywhere in ZIM! (smaller purchases are charged a nominal fee of $6).

ENJOY YOUR VIRTUAL SHOPPING SPREE!

For purposes of auditing the revenue earned from the online-store, you requested your audit trainee to gather information to gain an understanding of the process in place for orders placed on the website. This systems description has been documented in Working paper B2.

Client: MeBaby (Pvt) Ltd.	Year-end: 30 Sept 2014	WP B2
Prepared by: A. Trainee	Date: 3 Sept 2014	
Reviewed by:	Date	
Subject: Gaining an understanding of the process of sales in the online store.		

Objective: As part of the planning of our 2014 year-end audit, to gain an understanding of the process of online sales orders.

Per discussions with Mr Nickel, MeBaby's website manager, it has been ascertained that the following ordering process is followed:

Potential customers on the internet enter MeBaby's website at http://www.Mebaby.co.zw. Upon entering the website they may scroll through MeBaby's extensive online product catalogue, containing hundreds of items. For each individual item offered, the catalogue contains a picture of the item, together with a product code and the price of the item. Should an item be temporarily unavailable, this fact will be noted next to the picture.

Upon review of the items available, potential customers may choose to click on the "*Make a purchase*" option. They are then automatically directed to another screen whereby they are requested to provide their login details or else are instructed that they need to register on the site in order to continue and are then directed to another screen to complete this process.

Upon choosing a product, the customer marks a "tick-box" next to the item displayed in order to indicate that they wish to order the particular item. The customer is then asked to indicate the quantity (ies) per item. Upon these steps being completed, the relevant product code is automatically transferred to a provisional order form.

After the customer is finished with their product selections, they click on an option indicating that their order is complete. The final order form is then automatically prepared by the system and clearly displayed on the screen. This order form contains the product codes, a description of each item, the number of items as well as the price. The customer is then asked to confirm the correctness of the order by way of a pop up screen with a tick-box, in order to be transferred to the next screen page.

The system then automatically calculates the total amount due, which includes the delivery cost, should this be applicable. An automated control is built into the system to ascertain when delivery costs should be charged. The customer then has the option to accept, or reject, the order, by selecting and clicking on one button, either:

"*Accept order*", "*Change order*" or "*Cancel order*".

Upon accepting an order, the customer is directed to the next screen for payment. Payments for all orders may only be processed by credit card payment, no other payment options are offered. The customer is required to complete all of their credit card details before the order can be fully completed and processed.

All information from the sale is then automatically transmitted to MeBaby's sales system to be updated in the company's accounting records.

REQUIRED:

In regard to the process described in *Working Paper B2,* in respect of *orders placed on the MeBaby website*, describe **key IT controls** that you would expect to be in place in order to ensure the integrity and correctness of the online sales. **(25 marks)**

Wits Adapted

Solution

Controls over **registration/creating an online account** should include the following:

- The system should request specific personal and identification information, including an email address
    - The customer should be required to enter minimal information and drop down boxes should be used for some information required where possible. 1
    - *Alphanumerical tests* should be in place for names being entered to avoid incorrect information. 1
    - *Validity checks* should be in place to verify the validity of the email address provided. 1
    - A username and a Password should be required to be selected (possibly the username may be automatically provided by the system). 1
        - The password should be required to be a minimum number of characters. 1
        - Be alphanumeric. 1
- Error messages should be displayed on the screen as soon as any error occurs during any step in the above process and must be required to be corrected immediately before registration can continue. 1

Controls over **logins/access:**

- All usernames and passwords need to be saved securely in an authorisation table and future attempts for access must be confirmed against this table. 1
- After several (probably 3) unsuccessful attempts at logging in, the user should be '*locked out'* and only be able to enter the site upon an email/or sms being sent to the address/cell number provided upon registration in order for the password to be reset. 1
- Other logical access controls such as *firewalls* should be in place to prevent hackers gaining unauthorised access to the MeBaby site. 1
- *Virus software* must be on the system and updated on a continuous basis in order to prevent viruses from manipulating the website information. 1

Controls during the **ordering process:**

- A *drop down box* should be provided for the customer to select/highlight the quantity (ies) required per item. 1
- An automated data approval test needs to be in place to ensure that the quantity selected by the customer does not exceed the quantity that is currently available in stock. 1
    - The system therefore needs to be linked to the inventory master-file 1

- Online real time processing is necessary in regard to determining whether sufficient quantity is still on hand (ie. as soon as a product is sold, the inventory items still available need to be immediately automatically updated). 1
- Missing fields check should be in place - Should any of the required fields not be completed, e.g. the number of items, the ordering process should not be able to continue. 1
- Error messages should be displayed on the screen as soon as any error occurs during the process and must be required to be corrected immediately before the order process can continue. 1
- Each final order form created should have a unique sequential number, which can be used for follow up of duplicated/missing orders. 1
- During transmission of data on the site, *encryption* of data should be used to protect manipulation of data and confidential information. 1
- *Header and trailer* should be used to indicate the beginning and end of messages transferred in order to ensure completeness of data processed. 1

Controls over **credit card payments:**

- The user must be required to enter their credit card details for each transaction – reuse of details provided at an earlier purchase should not be allowed. 1
- *Field tests* should be in place when the credit card information is requested to ensure that the correct number of characters is supplied. 1
- The customers must be required to enter the expiry date on the card as well as the CCV code (Credit card verification number). 1
- The MeBaby website must be linked to bank sites in order to obtain confirmation of the validity of the credit card details provided as well as whether sufficient funds are available. 1
- The order should only be able to be processed once this confirmation has been received from the bank.1

Controls over **completion of sale**:

- The website should be compiled in such a way that the customer is advised on the site (and or on the invoice) that the transaction is a legal and binding sale that cannot be subsequently repudiated. 1
- Once an order has been processed, the final order and payment details should be emailed and/or sms'd to the customer immediately (using the details provided upon registration). 1
- The customer should be advised on this document of the process to follow should they not have transacted (ie. someone has 'hacked' into their account). 1

Master-file controls

- All customer information should be kept on a separate system (i.e. not on the website) to ensure that users on the site cannot access/hack this confidential information. 1

- Inventory Master-file controls:
    - Only authorised personnel at MeBaby should be able to access and make changes to the master-file data (products, prices etc.). 1
    - This should only be able to be done using logins/passwords. 1
    - All changes to the master-file should be logged and reviewed by management on a regular basis. 1